

CYROPAY LTD

Password and Authentication Policy

Document Classification: Internal
Document ID: POL-004
Version: 1.0
Policy Owner: Chief Information Security Officer (CISO)
Approved By: Chief Executive Officer (CEO)
Effective Date: May 2026
Review Date: May 2027
Status: Approved

1. Purpose

This policy establishes the requirements for password creation, management, and authentication for all users accessing CyroPay Ltd’s systems and information assets. It aims to prevent unauthorised access resulting from weak, reused, or compromised credentials.

2. Scope

This policy applies to:

- All employees, contractors, and third parties with accounts on CyroPay systems.
- All human and non-human (service) accounts.
- All authentication methods used to access CyroPay systems including passwords, PINs, API keys, and tokens.

3. Definitions

Term	Definition
Passphrase	A long password formed from multiple words, preferred over traditional short passwords

MFA	Multi-Factor Authentication — use of two or more verification factors
Service Account	Non-human account used by applications or automated processes
Credential Stuffing	Attack using stolen username/password pairs across multiple services
Password Manager	Approved tool for generating and storing strong, unique passwords

4. Roles and Responsibilities

4.1 CISO

1. Maintains this policy and ensures enforcement through technical controls.
2. Reviews and approves exceptions.

4.2 IT and Engineering Teams

1. Implement and maintain password and authentication controls.
2. Configure MFA, account lockout, and password complexity requirements.
3. Manage and rotate service account credentials.

4.3 All Users

1. Create strong, unique passwords for all accounts.
 2. Never share passwords or authentication credentials.
 3. Report any suspected credential compromise immediately.
 4. Use the company-approved password manager.
-

5. Policy Requirements

5.1 Password Requirements

1. Passwords must be a minimum of 12 characters in length.
2. Passwords must include at least one uppercase letter, one lowercase letter, one number, and one special character. Alternatively, a passphrase of at least four random words (minimum 20 characters) is acceptable.
3. Passwords must be unique and not reused across different systems or accounts.

4. Passwords must not include the user's name, username, company name, or common dictionary words.
5. Previously used passwords must not be reused within the last 12 password cycles.
6. Default or vendor-supplied passwords must be changed before a system is placed into production.

5.2 Password Management

1. All users must use the company-approved password manager for storing and generating credentials.
2. Passwords must not be written down, stored in plain text files, or shared via email or messaging platforms.
3. Passwords must be changed immediately upon suspected or confirmed compromise.
4. Users must not use the same password for CyroPay accounts as for personal accounts.

5.3 Multi-Factor Authentication (MFA)

1. MFA must be enforced for all privileged accounts, remote access, cloud administration, VPN, and finance systems.
2. MFA must be enforced for all external-facing systems and any access to production environments.
3. Phishing-resistant MFA methods (e.g. hardware security keys, FIDO2) are preferred for high-risk access.
4. SMS-based MFA is permitted only where more secure MFA methods are not technically feasible.

5.4 Account Lockout

1. Accounts must be locked after a maximum of 10 consecutive failed login attempts.
2. Locked accounts must remain locked for a minimum of 30 minutes or until unlocked by an administrator.
3. Account lockout events must be logged and monitored for anomalous patterns.

5.5 Service Account Credentials

1. Service account passwords must be stored in an approved secrets management tool.
2. Service account credentials must be rotated at least every 90 days.
3. Service accounts must not be used for interactive user logins.
4. All service account credentials must be inventoried and subject to annual review.

5.6 API Keys and Tokens

1. API keys and access tokens must be stored securely in an approved secrets manager.

2. API keys must not be hardcoded in source code or configuration files.
 3. Unused or expired API keys must be revoked promptly.
 4. API keys must be rotated at least every 90 days or immediately upon suspected compromise.
-

6. Compliance and Monitoring

Password policy compliance is enforced through technical controls including directory services configuration, MFA enforcement, and secrets management tooling. Compliance is reviewed through periodic access reviews and internal audits.

7. Exceptions

Any exceptions must be documented, risk assessed, approved by the CISO, and include compensating controls. Temporary exceptions must include an expiration date.

8. Related Documents

1. POL-001 Information Security Policy
 2. POL-003 Access Control Policy
 3. POL-009 Remote Working Policy
-

9. ISO/IEC 27001:2022 Annex A Mapping

Annex A Control	Description
A.5.17	Authentication information
A.8.2	Privileged access rights
A.8.5	Secure authentication

10. Document Control

Version	Date	Author	Changes
1.0	May 2026	CyroPay GRC Team	Initial version